

MITRE ATT&CK Practical Capstone Project

Operation Nightfall

Investigating a Simulated Intrusion and Building ATT&CK-Based Detection Coverage

Written Incident & ATT&CK Analysis Report

Student	StudentName
Role	Junior SOC Analyst / Threat Detection Analyst, BrightWave Logistics Ltd.
Project type	Individual Threat Analysis, SOC and Detection Engineering Capstone
ATT&CK version consulted	ATT&CK Enterprise v19.2 (August 2026 update), consulted 19 September 2026
Course taxonomy	14 tactics (Reconnaissance to Impact) retained as taught; differences with the live matrix are documented in Section 6
GitHub repository	brightwave-mitre-attack-capstone
Date	19 September 2026

All evidence in this report is synthetic and was analysed as if it came from an authorized internal incident investigation. No malware, payloads, credential-dumping commands or exploit steps are included.

2. Table of Contents

3. Executive Incident Summary 3

4. Evidence and Timeline 3

5. Analyst Assumptions and Confidence 4

6. ATT&CK; Mapping Method 4

7. Tactic-by-Tactic Analysis 5

8. Attack Path / Navigator Visualization 9

9. Detection Coverage Matrix 10

10. Detection Engineering Use Cases 10

11. Threat Hunting Plan 11

12. Incident Response and Recovery Priorities 11

13. Top Defensive Improvements 12

14. Conclusion 12

15. References 12

16. Appendix 14

3. Executive Incident Summary

What appears to have happened. On Monday at 11:40 a finance employee received a targeted email from a look-alike domain. Within minutes the account signed in from an unusual place, a script ran from an Office program, and the attacker set up a way to get back in. Over the next two hours the attacker got an administrator login, tried to reach stored passwords, looked around the network, moved to the file server, copied and zipped finance and customer files, kept contact with an outside server and sent a large amount of data out. On Tuesday at 07:50 staff found the shared files unreadable.

Who and what is affected. The finance worker's laptop and account, at least one administrator account, and the Windows file server. Until proven safe, treat anything those accounts can reach, including Microsoft 365, as possibly exposed.

What information is at risk. Finance and customer export files (E-11, E-12) that were probably part of the large upload (E-14). We do not yet know how many records were taken or whether they include personal or payment details.

Business impact. Staff cannot open shared files, which slows invoicing, bookings and daily work. If data theft is confirmed, BrightWave may need to notify customers and regulators and could face legal and reputation damage.

What to do first. (1) Save evidence and log every action. (2) Lock or reset the finance and admin accounts and end active sessions. (3) Disconnect the affected laptop and file server using approved tools. (4) Block the attacker's domain and upload destination through change control. (5) Protect backups before restoring. (6) Tell management and legal about possible data exposure.

Evidence behind this. Entry: E-02, E-03. Foothold: E-04 to E-08. Looking around and reaching the server: E-09, E-10. Data theft: E-11 to E-14. Impact: E-15. We are highly confident an attack happened, moderately confident about how it started and how much data left, and less sure what exactly damaged the files.

How to read this report. Every tactic in Section 7 starts with an *In simple words* line. Unfamiliar terms are explained in the Glossary (Appendix D). Sections 4 to 6 show the evidence and method, Section 7 covers all 14 course tactics, Sections 8 to 11 give the attack path, detection coverage, detections and hunts, and Sections 12 to 14 give the response plan, improvements and conclusion.

4. Evidence and Timeline

The timeline explains what each observation shows *before* any technique name is attached. The **Type** column separates **Fact** (stated in the evidence pack), **Inference** (reasoned from facts) and **Assumption** (needed to continue but unproven).

ID	Time / source	Observation (fact)	Analyst interpretation	Type	Conf.	Next question / evidence needed
E-01	Mon 08:15 Public / OSINT	Employee names, job titles and email patterns are discoverable on public pages.	Information exists that lets an attacker pick targets and build believable lures. Attacker use of it is not proven.	Fact + Assumption	Low	Do the lure's names/roles match public pages? Any scraping of the website or social pages?
E-02	Mon 11:40 Email gateway	New external look-alike domain sends a targeted message to a finance employee.	Likely targeted phishing from attacker-prepared infrastructure; probable entry vector.	Inference	Medium	Domain age/registrar, SPF/DKIM/DMARC results, links or attachments, other recipients.
E-03	Mon 11:44 Identity	Finance user signs in successfully after opening the message; sign-in risk marked unusual.	Possible credential capture or token theft; a legitimate but unusual sign-in is the alternative.	Inference	Medium	Sign-in IP/ASN/geo, device, MFA result, session/token IDs, conditional access outcome.
E-04	Mon 11:47 Endpoint	A scripting engine launches from an Office-related process (command content omitted).	Possible user-triggered execution chain following the message.	Inference	Medium	File, process tree, hash, user, parent/child details, command line via authorized EDR.
E-05	Mon 11:51 Endpoint	New scheduled execution entry set to run at user sign-in.	Probable persistence so access survives logoff or reboot.	Inference	Medium	Task name, author, trigger, action path, creation time; registry Run keys and startup folder.
E-06	Mon 12:03 Endpoint security	Local protection setting changed, then restored.	Possible short window to reduce visibility; automatic restoration by tamper protection is an alternative.	Inference	Medium	Who/what changed it, mechanism, activity during the window, tamper-protection logs.
E-07	Mon 12:10 Identity / endpoint	Privileged account signs in on the same workstation outside its normal pattern.	Likely use of a stolen or exposed privileged credential; exploitation not evidenced.	Inference	Medium	Logon type and source, admin's real location, ticket for the activity, authentication events.
E-08	Mon 12:14 Endpoint	Alert: attempted access to stored credential material.	Credential access was attempted; whether it succeeded is unknown.	Fact + Inference	Medium	EDR alert detail, source and target process, blocked or allowed, later logons with new credentials.

ID	Time / source	Observation (fact)	Analyst interpretation	Type	Conf.	Next question / evidence needed
E-09	Mon 12:20 Endpoint / network	Workstation queries users, groups, nearby systems, shares and domain resources.	Discovery burst to plan movement and find data; admins can do this legitimately.	Inference	Medium	Which tools/queries, by which account, and what activity followed.
E-10	Mon 12:31 File server	Finance account connects to the file server with a remote administration protocol it does not normally use.	Likely lateral movement from the workstation to the file server.	Inference	Medium	Which protocol, logon type, source host, why the finance account had this right.
E-11	Mon 12:42 File server	Large set of finance and customer export files copied into a temporary staging folder.	Data collection and staging before transfer out.	Fact + Inference	High	Folder path, file list, count, size, account and session.
E-12	Mon 12:49 File server	Staged files compressed into an archive with a generic name.	Archive prepared for exfiltration.	Inference	High	Archive size and hash, tool used, whether it later left the network.
E-13	Mon 13:05 Firewall	Periodic encrypted web connections to a rare external domain every few minutes.	Beacon-like command and control; a benign update agent is the alternative.	Inference	Medium	Initiating process, DNS/proxy/TLS metadata, domain age and reputation.
E-14	Mon 14:18 Firewall / proxy	Large encrypted outbound transfer to an unfamiliar external service.	Probable exfiltration of the archive; size match not verified.	Inference	Medium	Bytes out vs archive size, destination identity, session source and timing.
E-15	Tue 07:50 File server / users	Many shared documents cannot be opened and file names changed; operations disrupted.	Business impact consistent with encryption or mass rename; other causes possible.	Inference	Medium	Sample file analysis, ransom note (none reported), backup state, scope of shares.

5. Analyst Assumptions and Confidence

Confidence scale. **High:** directly observed and unambiguous. **Medium:** consistent with the evidence but plausible alternatives exist. **Low:** plausible but weakly supported or dependent on an assumption.

Facts (from the evidence pack)

- A look-alike external domain emailed a finance employee (E-02) and the user signed in with an unusual risk marker (E-03).
- A script engine ran from an Office process, a logon-triggered scheduled entry appeared, a protection setting changed and was restored (E-04 to E-06).
- A privileged account signed in on the workstation outside its pattern and a credential-access alert fired (E-07, E-08).
- Discovery activity, unusual remote access to the file server, bulk copying, archiving, periodic beaconing and a large outbound transfer occurred (E-09 to E-14).
- Files became unavailable and names changed on Tuesday morning (E-15).

Inferences (reasoned, labelled with confidence)

- E-02 was the entry vector (Medium). E-03 shows a compromised or stolen credential rather than a benign unusual sign-in (Medium).
- The privileged account was stolen or exposed, not obtained by exploitation (Medium). The credential-access attempt may have succeeded (Low to Medium).
- The archive from E-12 is what left the network in E-14 (Medium). The E-13 beacon and the E-14 transfer used attacker infrastructure (Medium).
- E-15 is destructive or encryption-related activity by the same actor (Medium).

Assumptions (unproven, needed to continue)

- The attacker used the public information in E-01 (Low). A single actor is responsible for E-01 to E-15 (Medium).
- Sub-techniques cannot be selected where the evidence omits the tool, protocol or command; base techniques are used and marked as such.
- Current detection coverage in Section 9 is assumed from the alerts the scenario reports (E-03, E-06, E-08) and the absence of others.

6. ATT&CK Mapping Method

Tactic, technique and sub-technique in simple words. A **tactic** is the attacker's goal (the *why*). A **technique** is the way they try to reach it (the *how*). A **sub-technique** is a more specific version of the how. Example: the tactic *Initial Access* (goal: get in) uses the technique *T1566 Phishing* (how: a fake email), and the sub-technique *T1566.002* means the email carried a malicious link.

How I mapped each event.

- Write down the fact exactly as the evidence says it.
- Explain in plain words what the attacker was probably doing.
- Pick the tactic (the goal) and then the technique from the official MITRE page.
- Add a sub-technique only if the evidence proves the detail; otherwise use the main technique.
- Give a confidence label (High, Medium, Low) and name the alternative explanation.
- One event can fit more than one tactic or technique. For example T1078 Valid Accounts is used for several goals.

Version and naming differences. I used **ATT&CK Enterprise v19.2 (August 2026 update)**, checked on 19 September 2026. The course teaches 14 tactics and I kept them. The live MITRE matrix now has 15, because in April 2026 (v19) MITRE replaced *Defense Evasion* with two tactics: **Stealth** (TA0005) and **Defense Impairment** (TA0112). So E-06 is reported under the course tactic **Defense Evasion** and cross-referenced to **Defense Impairment**. MITRE also merged T1562 and T1562.001 into **T1685 Disable or Modify Tools**, so I use T1685 and mention the old ID. v19 added a Social Engineering technique (T1684); I keep T1566 Phishing as the main mapping for E-02 and flag T1684 for review.

Evid.	Course tactic	ID	Technique / sub-technique	Reasoning	Conf.
E-01	Reconnaissance	T1589	Gather Victim Identity Information (.002 Email Addresses, .003 Employee Names)	Public names and email patterns enable target selection.	Low
E-01	Reconnaissance	T1591	Gather Victim Org Information (.004 Identify Roles)	Job titles reveal who handles finance.	Low
E-02	Resource Development	T1583.001	Acquire Infrastructure: Domains	A look-alike domain has to be registered before use.	Medium
E-02	Initial Access	T1566	Phishing (sub-technique unknown: link vs attachment)	Targeted message is the most likely entry vector.	Medium
E-03	Initial Access	T1078	Valid Accounts	Successful sign-in with unusual risk suggests stolen credentials.	Medium
E-04	Execution	T1204	User Execution	Execution followed the user opening the message.	Medium
E-04	Execution	T1059	Command and Scripting Interpreter (engine unknown)	A script engine launched from an Office process.	Medium
E-05	Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	Entry runs at user sign-in; alternative is a Run key (T1547.001).	Medium
E-06	Defense Evasion (v19: Defense Impairment)	T1685	Disable or Modify Tools (was T1562.001 before v19)	Protection setting changed then restored.	Medium
E-07	Privilege Escalation	T1078 (.002)	Valid Accounts: Domain Accounts	Privileged account used out of pattern; no exploit evidence.	Medium
E-08	Credential Access	T1003	OS Credential Dumping (sub-technique unknown)	Alert shows attempted access to stored credential material.	Medium
E-09	Discovery	T1087	Account Discovery	Users queried.	Medium
E-09	Discovery	T1069	Permission Groups Discovery	Groups queried.	Medium
E-09	Discovery	T1018	Remote System Discovery	Nearby systems queried.	Medium
E-09	Discovery	T1135	Network Share Discovery	Shared folders queried.	Medium
E-10	Lateral Movement	T1021	Remote Services (protocol unknown)	Remote admin protocol used from workstation to file server.	Medium
E-11	Collection	T1074	Data Staged (.001 Local vs .002 Remote depends on the staging host)	Files copied into a temporary staging folder.	High
E-11	Collection	T1039	Data from Network Shared Drive	Source data sits on the file server share.	Medium
E-12	Collection	T1560	Archive Collected Data	Staged files compressed with a generic name.	High
E-13	Command and Control	T1071.001	Application Layer Protocol: Web Protocols	Periodic encrypted web connections to a rare domain.	Medium
E-13	Command and Control	T1573	Encrypted Channel	Traffic is encrypted; inspection limited to metadata.	Medium
E-14	Exfiltration	T1567	Exfiltration Over Web Service	Large encrypted transfer to an unfamiliar external service.	Medium
E-14	Exfiltration	T1041	Exfiltration Over C2 Channel (alternative)	Applies if the transfer used the E-13 channel.	Low
E-15	Impact	T1486	Data Encrypted for Impact	Files unavailable and renamed; alternative is T1485 Data Destruction.	Medium

7. Tactic-by-Tactic Analysis

Each subsection starts with a plain-language summary, then gives the mapping, the evidence and logs needed, and the defensive recommendations. Technique IDs are listed in Section 6.

7.1 Reconnaissance (E-01)

In simple words: Before attacking, the criminal studies the company using public information, such as who works in finance and how emails are written. We cannot hide public information, so we protect the later steps.

What an attacker could learn. Public pages and social media expose employee names, titles and the email format; job adverts, DNS and certificates can reveal technologies such as Microsoft 365, VPN and the booking portal. This supports T1589, T1591 and T1593 (Search Open Websites/Domains).

Practical work. Scenario clue: E-01. Defensive actions: trim unnecessary staff detail online, use role-based mailboxes for finance, limit directory harvesting, publish staff guidance on social media and brief finance staff on tailored lures.

Can and cannot prevent: defenders cannot stop passive collection of public information, so they should assume it is available and focus on later stages.

7.2 Resource Development (E-02)

In simple words: The attacker prepares tools before the attack, for example a website name that looks almost like ours so their emails look real.

Evidence. A new look-alike domain (E-02) shows attacker-prepared infrastructure (T1583.001). The rare C2 domain (E-13) and the exfiltration service (E-14) may also be attacker-controlled (assumption).

Monitoring. Track newly registered look-alike domains, certificate transparency entries, and DMARC and impersonation reports; add gateway rules for look-alike sender domains.

Unknowns and intelligence needed. Registration date, registrar, hosting, and whether E-02, E-13 and E-14 share infrastructure. Passive DNS, WHOIS history and threat intelligence would help.

7.3 Initial Access (E-02, E-03)

In simple words: This is how they first got in: most likely a convincing email to a finance worker, then signing in with that worker's account.

Likely entry. A targeted phishing message (T1566) followed by a successful sign-in (E-03, T1078). Whether it used a link or an attachment is unknown, and stolen credentials from another source remain an alternative.

Controls. Email authentication and impersonation protection, link and attachment detonation, phishing-resistant MFA, conditional access on risky sign-ins, and an easy way to report suspicious mail.

Evidence needed. Message headers with SPF/DKIM/DMARC results, URL click and attachment logs, message trace for other recipients, sign-in logs with IP, device, MFA method and token details.

7.4 Execution (E-04)

In simple words: The attacker's script ran on the finance laptop, probably after the worker opened the email's file or link.

Mapping. T1204 User Execution and T1059 Command and Scripting Interpreter; the sub-technique depends on the engine, which E-04 does not name.

Evidence to request. Process tree with parent/child details, command line and script content through authorized EDR, file origin and hash, user context, and network activity from the process.

Safe detection hypothesis. An Office application starting a script interpreter is rare for finance users; alert on that parent/child pair (Section 10, D2) and block it with attack surface reduction rules where business use allows.

7.5 Persistence (E-05)

In simple words: The attacker created an automatic task so they could get back in every time the user signed in, even after a restart.

Mapping. T1053.005 Scheduled Task, with T1547.001 (Registry Run Keys/Startup Folder) as the alternative.

Artifacts that would confirm it. Task definition (name, author, trigger, action path, creation time), Security event 4698, Task Scheduler operational log, Run keys, startup folder and autoruns output.

Recommendations. Capture the artifact before removal, hunt for the same task across the fleet, alert on new logon-triggered tasks created by non-admin accounts, and rebuild the workstation if trust cannot be restored.

7.6 Privilege Escalation (E-07)

In simple words: The attacker moved from a normal account to an administrator account, most likely by using stolen admin login details rather than breaking software.

Stolen credentials vs exploitation vs misconfiguration. *Stolen credentials* (T1078.002, Medium): the logon type and source, an admin who was elsewhere, and the E-08 alert. *Exploitation* (T1068, Low): unpatched software, crashes,

unexpected SYSTEM child processes. *Misconfiguration*: excess local admin rights or group changes. The evidence supports the first only.

Recommendations. Tiered admin model, privileged access workstations, just-in-time and just-enough administration, deny admin logon to standard workstations, unique local admin passwords, MFA and alerts on privileged sign-ins.

7.7 Defense Evasion (E-06)

In simple words: The attacker briefly changed a security setting so their activity would be harder to catch.

Mapping. T1685 Disable or Modify Tools (T1562.001 before v19). On the live matrix this sits under Defense Impairment; the course tactic Defense Evasion is kept. Restoration suggests either a short window of reduced protection or automatic reversal by tamper protection; the evidence cannot separate the two.

Alerts that should fire. Any change to protection settings or exclusions, security service state changes, audit policy changes and log clearing that lacks an approved change.

Controls. Tamper protection, restricted local admin, off-host log forwarding, configuration drift monitoring and separation of security-tool administration from general admin.

7.8 Credential Access (E-08)

In simple words: The attacker tried to grab saved passwords from the laptop. Our security tool noticed, but we do not know if it worked.

Mapping. T1003 OS Credential Dumping (sub-technique unknown; T1555 Credentials from Password Stores is an alternative). Success is not proven.

Useful logs. EDR alert details (source and target process, blocked or allowed), process-access telemetry, Security event 4688, credential protection status and any later logon by the exposed accounts.

Recommendations. Treat the finance and privileged accounts as compromised: reset passwords, revoke sessions and tokens, enforce MFA, review privileged group membership, enable credential protection features and remove cached admin credentials. If domain-level credentials are suspected, follow the organization's domain credential reset procedure.

7.9 Discovery (E-09)

In simple words: The attacker looked around: who the users are, which groups exist, and which computers and shared folders are nearby.

Mapping. T1087 Account Discovery, T1069 Permission Groups Discovery, T1018 Remote System Discovery and T1135 Network Share Discovery.

Legitimate overlap. Admins, inventory and vulnerability scanners and login scripts all enumerate these resources. Context reduces false positives: the user's role (a finance user rarely enumerates the domain), the host baseline, the size of the burst and what follows (for example remote access, as in E-10).

Telemetry source	What it shows	Useful fields
Endpoint process creation (EDR / Sysmon)	Enumeration tools and queries run on the workstation	Parent/child, command line, user, host, time
Domain controller / directory logs	LDAP and directory queries about users and groups	Client IP, query scope, volume
Windows Security events 4798 / 4799	Local user and group membership enumeration	Caller account, target, host
File server events 5140 / 5145	Share and file access	Account, share, source IP
Firewall / NetFlow	Fan-out to many internal hosts and ports (SMB, LDAP)	Source, destination count, ports
DNS logs	Lookups of many internal hostnames	Client, query names, time

7.10 Lateral Movement (E-10)

In simple words: The attacker moved from the finance laptop to the file server, where the important files are kept.

Mapping. T1021 Remote Services; the sub-technique (for example RDP T1021.001, SMB/Windows Admin Shares T1021.002 or WinRM T1021.006) depends on the protocol, which E-10 does not name.

Telemetry needed. Security events 4624 (logon type 3 or 10), 4648, 5140/5145 and 7045, network flows for SMB, RDP and WinRM ports, and EDR remote execution events. Also check why the finance account had this right at all.

Recommendations. Segment workstations from server admin ports, allow remote administration only from jump hosts or privileged access workstations, apply host firewall rules and deny-logon rights, and require MFA for admin protocols.

7.11 Collection (E-11, E-12)

In simple words: The attacker gathered the files they wanted into one folder and zipped them into one package, ready to steal.

Mapping. T1039 Data from Network Shared Drive, T1074 Data Staged and T1560 Archive Collected Data. Staging on the same server that holds the data points to local staging (.001); staging on a different system would be .002.

Evidence. File audit events (4663, 5145), file creation events and the USN journal or MFT timestamps, SMB session logs, and the archive's size, hash and creation time.

Monitoring. Alert on bulk reads or copies, new staging folders, archive creation on servers by non-backup accounts, and access to decoy files placed in sensitive shares.

7.12 Command and Control (E-13)

In simple words: The infected laptop 'phoned home' to the attacker's server every few minutes, like a heartbeat, to wait for instructions.

Mapping. T1071.001 Web Protocols and T1573 Encrypted Channel.

Useful data. DNS (first-seen domain, query timing), proxy (host, SNI, user agent, bytes), firewall (five-tuple, duration, bytes), EDR network events (initiating process) and TLS metadata (JA3/JA4, certificate issuer and age).

Detection idea. Flag hosts with at least 12 connections at regular intervals (low variation) to a domain seen by two or fewer internal hosts and registered recently (Section 10, D9). The alternative is a benign update or telemetry agent.

7.13 Exfiltration (E-14)

In simple words: The stolen package was sent out of the company to an outside service.

Mapping. T1567 Exfiltration Over Web Service (T1041 if the same channel as E-13). Confidence is Medium because the byte count is not matched to the archive.

Estimated exposure (no claim of certainty). Possibly the archive from E-12: finance records, invoices, and customer export data such as names, contact and booking details. Volume, record count and presence of personal or payment data are unknown.

Recommendations. Block the destination, isolate the source hosts, preserve proxy and firewall logs, add egress allow-listing for servers, upload-volume alerts and DLP, and escalate to management, legal counsel and the data protection contact for notification decisions.

7.14 Impact (E-15)

In simple words: The final damage: shared files became unreadable and renamed, so people could not work.

Mapping. T1486 Data Encrypted for Impact; alternatives are T1485 Data Destruction or mass renaming. A sample file and any note would confirm the cause.

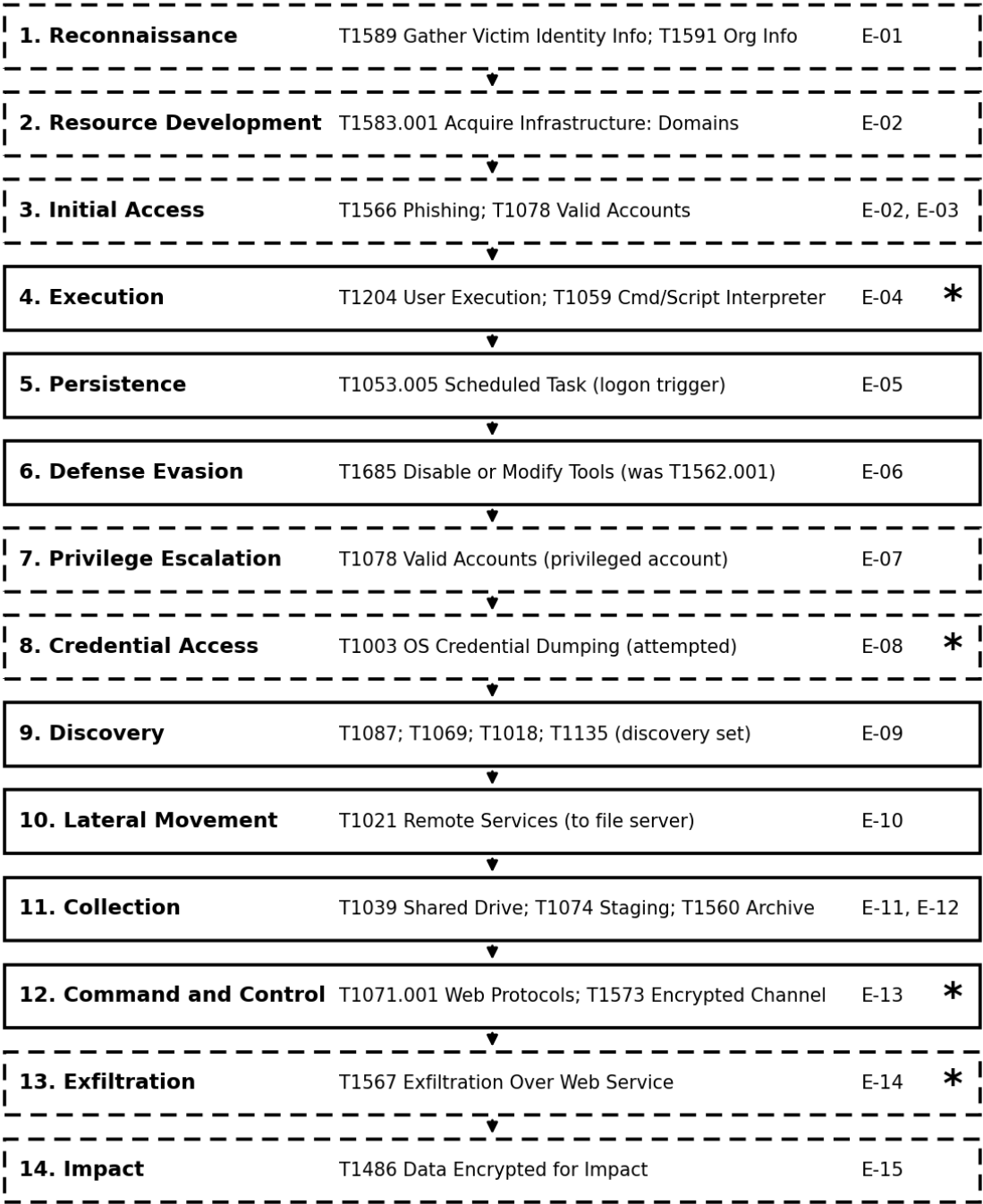
Recovery priorities and evidence. Preserve memory, disk images and logs before rebuilding; identify clean offline or immutable backups; restore the file server in an isolated segment, then finance and booking data; reconnect users only after credential resets and validation.

Resilience controls. Immutable and offline backups, regular restore tests, segmentation of the file server, restricted admin protocols and monitoring of mass file modification.

8. Attack Path / Navigator Visualization

The diagram follows evidence time. A solid border is **Observed**, a dashed border is **Suspected**, a dotted border is **Not Observed** (none in this path) and * marks a **Priority Detection Gap**. Technique notes link back to evidence IDs in Section 6. The Navigator layer (navigator-layer.json) in the repository uses the same statuses and ATT&CK Enterprise v19.2 (August 2026 update).

Operation Nightfall - Likely Attack Path



Legend



Observed



Suspected



Not Observed



Priority Detection Gap

Order follows evidence time (E-01 to E-15). ATT&CK Enterprise v19.2.

Course tactic Defense Evasion corresponds to v19 Defense Impairment (TA0112) for E-06.

9. Detection Coverage Matrix

Current coverage is an assumption drawn from the scenario: alerts fired for E-03, E-06 and E-08 but nothing was contained, and no other alerts are reported. *Partial* means an alert exists but did not stop the intrusion; *Gap* means no detection is evidenced. Fourteen entries relate to the incident and one is a related use case.

Technique	Behavior to detect	Telemetry / log source	Current coverage	Detection idea	Evid.
T1583.001	Look-alike domain used to email staff	Email gateway, threat intel, certificate transparency	Gap	Alert on sender domains within a small edit distance of the company domain; watch new look-alike registrations	E-02
T1566	Targeted external message to finance staff	Email gateway / M365 message trace	Partial	Flag first-time external senders with look-alike domains to finance; detonate links and attachments	E-02
T1078	Unusual or risky sign-in for a user or admin	Identity sign-in and risk logs	Partial	Require re-authentication or block on medium/high risk for finance and privileged users	E-03, E-07
T1204 / T1059	Office application spawning a script engine	Endpoint process telemetry	Gap	Alert on rare Office-to-interpreter parent/child chains	E-04
T1053.005	New logon-triggered scheduled task	Endpoint events, Security 4698	Gap	Alert on new tasks with logon triggers created by non-admin accounts	E-05
T1685	Security setting or logging change	EDR health and tamper events, audit policy events	Partial	High-severity alert on any change without an approved ticket	E-06
T1003	Attempted access to credential material	EDR credential-access alerts	Partial	Auto-isolate the host and force credential reset on alert	E-08
T1087 / T1069 / T1018 / T1135	Discovery burst from a workstation	Process telemetry, DC and share logs	Gap	Count distinct enumeration activities per user in 10 minutes	E-09
T1021	Remote admin access to a server by a non-admin	Authentication logs, NetFlow	Gap	Alert on network/remote logons to servers by accounts outside the server-admin group	E-10
T1074 / T1039	Bulk copy into a staging folder	File server audit logs	Gap	Threshold on files or MB created per account in 15 minutes	E-11
T1560	Archive creation on a file server	File events, EDR	Gap	Alert on archives created after bulk reads by the same account	E-12
T1071.001 / T1573	Beacon-like traffic to a rare domain	DNS, proxy, firewall, TLS metadata	Gap	Regular-interval, rare, newly registered domain scoring	E-13
T1567 / T1041	Large outbound encrypted transfer	Firewall and proxy byte counts	Gap	Bytes out above a per-host baseline to non-sanctioned destinations	E-14
T1486	Mass file modification or rename	File server events, EDR	Gap	Alert on file modification or rename rate spikes on shares	E-15
T1114.003	New mailbox forwarding rule (related use case)	M365 unified audit log	Unknown	Alert on external forwarding set by admins or outside change windows	Part 10

10. Detection Engineering Use Cases

All detections are defensive and intended for synthetic or authorized data only. Queries are in Appendix A. Detection content contains no payloads, credential-dumping commands or steps for disabling defenses. Field names follow Microsoft Defender/Sentinel schemas as an example and should be adapted to the log platform in use.

#	Use case and why it matters	Data source and fields	Logic	False positives and tuning	Sev.	Response
D1	Unusual sign-in (T1078). Stolen credentials are the entry point for later stages.	Sign-in logs: user, IP, country, device, risk level, result	Successful sign-in from an IP or country new for the user in 30 days, with medium/high risk or a privileged account	Travel, VPN, new phones. Allow known VPN egress IPs; watchlist privileged users; travel notices	High	Re-authenticate, revoke sessions, contact user out of band
D2	Office spawns script engine (T1204, T1059). Common user-triggered execution chain.	Process events: parent, child, user, device, command line	Parent is an Office application and child is a script interpreter or command shell	Legacy macros, finance add-ins, IT automation. Allow-list signed macros; scope to finance and high-risk groups	High	Isolate host, collect process tree, block sender
D3	New scheduled persistence (T1053.005). Shows the attacker plans to return.	Security 4698 / EDR task events: name, author, trigger, action path	New task with logon or boot trigger by a non-admin account, or action path in a user-writable folder	Installers and updaters. Allow vendor-signed tasks; baseline the golden image	Medium-High	Review task, capture then remove, hunt across fleet
D4	Security or logging change (T1685). Reduces visibility for later stages.	EDR health/tamper events, audit policy 4719, service state, log cleared 1102	Protection setting, audit policy or logging service changed with no matching approved change	Patching and maintenance. Correlate with change windows; exclude approved maintenance hosts	High	Triage now, restore and verify, isolate if unexplained

#	Use case and why it matters	Data source and fields	Logic	False positives and tuning	Sev.	Response
D5	Credential-access alert (T1003). Compromised credentials multiply attacker reach.	Security alerts, logon events: alert name, host, account	Credential-access alert followed by a logon of the same account on a new host within 24 hours	Backup and security agents touching credential stores. Allow-list signed agents	Critical	Isolate, reset credentials, revoke sessions
D6	Discovery burst (T1087, T1069, T1018, T1135). Precedes lateral movement.	Process events, DC logs, 4798/4799, 5140: user, host, tool	Four or more distinct enumeration activities by one user or host in 10 minutes, user not in IT	Admins and scanners. Exclude scanner hosts; baseline by role	Medium	Check user context, review follow-on activity
D7	Unexpected server remote access (T1021). Marks the move to the crown jewels.	Logon events 4624/4648, NetFlow: account, source, logon type	Network or remote-interactive logon to file server by an account outside the server-admin group or from a workstation	Helpdesk and admin jump hosts. Allow-list jump hosts and admin group	High	Block, review session, isolate source
D8	Staging and compression (T1074, T1560). Last step before data leaves.	File events on servers: path, size, account, time	Over 500 files or 1 GB created in a folder in 15 minutes, or an archive created after bulk reads	Backups, migrations, legitimate archiving. Exclude backup accounts and paths; role thresholds	High	Preserve archive, disable account, escalate
D9	Beaconing to a rare domain (T1071.001, T1573). Reveals active attacker control.	DNS/proxy/firewall: source, domain, time, bytes, SNI	12+ connections at regular intervals (variation under 25%) to a domain seen by two or fewer hosts	Telemetry and update agents. Allow-list known SaaS; add domain age and reputation	Medium-High	Block via change control, find initiating process
D10	Large encrypted outbound transfer (T1567, T1041). Indicates data theft.	Firewall/proxy: source, destination, bytes out	Hourly bytes out above three times the host's 99th percentile to a non-sanctioned destination	Cloud backups, large uploads. Allow sanctioned services; per-role baselines	High	Block, contain host, notify IR lead and legal

11. Threat Hunting Plan

Hunt ID	Hypothesis	Data source	Search window	What would increase confidence?
H-01	Other users received the same targeted message	Email gateway / M365 message trace	7 days	Same sender or domain, similar subject, link or attachment indicators
H-02	Other endpoints carry the same logon-triggered scheduled entry	EDR, Security 4698, autoruns	30 days	Same task name, action path or hash on other hosts
H-03	Other accounts signed in from the same IP, ASN or device pattern	Sign-in logs	14 days	Same source with medium/high risk or first-time sign-ins
H-04	Other servers were reached with the same remote admin protocol	Authentication logs, NetFlow	14 days	Non-admin accounts logging on to servers from workstations
H-05	Other hosts beacon to the same or similar rare domains	DNS, proxy, firewall	30 days	Regular intervals, same domain or certificate, shared TLS fingerprints
H-06	Additional staging folders or archives exist on other servers	File server and EDR file events	30 days	Archives with generic names, bulk reads before creation
H-07	The privileged account was used elsewhere after E-07	Domain controller and endpoint logons	7 days	Logons from unexpected hosts, new group changes, new tasks or services

12. Incident Response and Recovery Priorities

Actions are ordered as they should be considered. **Contain first:** the compromised accounts and the two confirmed hosts, because stolen credentials give access beyond any one endpoint. Evidence capture happens first or alongside so that containment does not destroy it.

#	Action	Phase	Why / notes
1	Preserve evidence and record time, source and analyst actions	Immediate	Volatile data and logs first; maintain a case log and chain of custody
2	Protect affected accounts and revoke suspicious sessions and tokens	Immediate	Finance user and privileged account; enforce MFA re-registration where appropriate
3	Isolate confirmed compromised endpoints using authorized security tooling	Immediate	Finance workstation and file server; keep powered on for forensics
4	Block confirmed malicious infrastructure through approved change processes	Immediate	Look-alike domain, C2 domain and outbound destination; keep records of blocks
5	Reset or rotate affected credentials based on scope	Eradication	Start with exposed accounts; widen if E-08 succeeded
6	Remove persistence and remediate vulnerable or misconfigured systems	Eradication	Scheduled entry, excess admin rights, remote admin exposure
7	Validate backups and restore in a controlled sequence	Recovery	Check backups are clean, then file server, finance, booking, general shares
8	Increase monitoring for recurrence	Recovery	Enable the detections in Section 10 and run the hunts in Section 11

#	Action	Phase	Why / notes
9	Complete lessons learned and control improvements	Post-incident	Update playbooks; track the improvements in Section 13

Recovery priorities. (1) Preserve evidence before rebuilding; (2) identify clean immutable or offline backups; (3) restore the file server in an isolated segment; (4) restore finance and booking data first; (5) reconnect users in waves after credential resets; (6) confirm no beaconing or new persistence before returning to normal operations. **Business and legal escalation:** inform management, legal counsel, the data protection contact and the cyber insurer, and review breach-notification obligations if exfiltration is confirmed.

13. Top Defensive Improvements

#	Improvement	Addresses	Related techniques
1	Phishing-resistant MFA and risk-based conditional access for finance and privileged users, with look-alike domain monitoring and DMARC enforcement	E-02, E-03, E-07	T1566, T1078, T1583.001
2	EDR hardening: tamper protection, blocking Office child script processes, auto-isolation on credential-access alerts	E-04, E-06, E-08	T1204, T1059, T1685, T1003
3	Privileged access management: tiered admin, privileged access workstations, just-in-time admin, deny admin logon on standard workstations	E-07, E-10	T1078, T1021
4	Egress and DNS controls: proxy filtering of new and rare domains, server egress allow-listing, upload-volume alerts and DLP	E-13, E-14	T1071.001, T1573, T1567
5	Resilience: immutable offline backups with restore tests, file server segmentation, bulk-access and staging alerts	E-11, E-12, E-15	T1074, T1560, T1486

Five techniques to monitor most closely after recovery: T1566 Phishing, T1078 Valid Accounts, T1003 OS Credential Dumping, T1021 Remote Services and T1567 Exfiltration Over Web Service.

14. Conclusion

Likely initial access path. A targeted phishing message from a look-alike domain to a finance employee (E-02), followed by a successful but unusual sign-in (E-03). Confidence: Medium.

Likely progression. Execution from an Office process, scheduled persistence, a brief weakening of protection, privileged account use, a credential-access attempt, discovery, remote access to the file server, staging and archiving, beaconing, exfiltration and finally disruption of shared files (E-04 to E-15).

Accounts and systems most likely affected. The finance user's account and workstation, at least one privileged account, and the Windows file server. Microsoft 365 and other systems reachable with those credentials should be checked.

Data exposure. Finance and customer exports were staged and archived, and a large transfer followed. Exposure is probable but unconfirmed (Medium); contents, record counts and personal or payment data are unknown.

Business impact. Loss of access to shared files, disrupted operations and possible notification, contractual and reputational consequences.

Most important detection gaps. Alerts fired for risky sign-in, protection change and credential access (E-03, E-06, E-08) but nothing was contained; there was no detection of the scripting chain, server access, staging, beaconing or bulk outbound transfer.

Top five improvements. See Section 13: identity and email hardening, EDR hardening, privileged access management, egress and DNS controls, and resilient backups with segmentation.

What BrightWave should do next. Complete containment and credential resets, run hunts H-01 to H-07, confirm exfiltration scope with proxy and file server logs, restore from validated backups, deploy the ten detections, and complete lessons learned.

15. References

- MITRE ATT&CK Enterprise Matrix. <https://attack.mitre.org/matrices/enterprise/> (v19.2, consulted 19 September 2026)
- MITRE ATT&CK release notes, April 2026 (v19). <https://attack.mitre.org/resources/updates/updates-april-2026/>
- MITRE ATT&CK tactic pages: Stealth TA0005 <https://attack.mitre.org/tactics/TA0005/> ; Defense Impairment TA0112 <https://attack.mitre.org/tactics/TA0112/>
- MITRE ATT&CK technique pages (pattern <https://attack.mitre.org/techniques/T#####/> and [/#####/](https://attack.mitre.org/techniques/#####/) for sub-techniques): T1589, T1591, T1593, T1583.001, T1566, T1078, T1204, T1059, T1053.005, T1547.001, T1685, T1003, T1555, T1087, T1069, T1018, T1135, T1021, T1039, T1074, T1560, T1071.001, T1573, T1567, T1041, T1486, T1485, T1114.003, T1098.002, T1068.
- MITRE ATT&CK Navigator. <https://mitre-attack.github.io/attack-navigator/>

- NIST SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management (2025). <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- Microsoft Learn: Advanced hunting schema (Defender XDR) and Microsoft Entra ID Protection risk detections, used for the example field names.
- Sigma detection rule format specification. <https://github.com/SigmaHQ/sigma-specification>

16. Appendix

A. Selected detection queries (synthetic or authorized data only)

Queries are KQL-style, Sigma-style or Python pseudocode. Adapt table and field names to your platform and test in a lab before use.

D1 Unusual sign-in (KQL-style)

```
let known = SigninLogs
| where TimeGenerated between (ago(30d) .. ago(1d)) and ResultType == 0
| summarize KnownIPs = make_set(IPAddress) by UserPrincipalName;
SigninLogs
| where TimeGenerated > ago(1d) and ResultType == 0
| join kind=leftouter known on UserPrincipalName
| where not(set_has_element(KnownIPs, IPAddress))
| where RiskLevelDuringSignIn in ("medium","high")
   or UserPrincipalName in (PrivilegedAccountsWatchlist)
| project TimeGenerated, UserPrincipalName, IPAddress, Location, RiskLevelDuringSignIn
```

D2 Office application spawning a script engine (KQL-style)

```
DeviceProcessEvents
| where InitiatingProcessFileName in~ ("winword.exe","excel.exe","powerpnt.exe","outlook.exe")
| where FileName in~ ("powershell.exe","cmd.exe","wscript.exe","cscript.exe","mshta.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName
```

D3 Logon-triggered scheduled task by non-admin (Sigma-style)

```
title: Logon-triggered scheduled task created by a non-admin account
logsource: {product: windows, service: security} # or EDR ScheduledTaskCreated
detection:
  selection: {EventID: 4698}
  trigger: {TaskContent|contains: ['LogonTrigger', 'BootTrigger']}
  filter_admin: {SubjectUserName|startswith: 'adm-'}
  condition: selection and trigger and not filter_admin
level: high
```

D4 Security tool or logging configuration change (Sigma-style)

```
title: Security tool or logging configuration changed without approved change
logsource: {category: endpoint_security_audit}
detection:
  selection:
    event_type: [protection_setting_changed, audit_policy_changed,
                 logging_service_stopped, log_cleared]
  approved: {change_ticket|exists: true}
  condition: selection and not approved
level: high
```

D5 Credential-access alert correlated with new-host logon (KQL-style)

```
let credAlerts = SecurityAlert
| where Tactics has "CredentialAccess"
| project AlertTime = TimeGenerated, CompromisedHost, AccountName;
DeviceLogonEvents
| join kind=inner credAlerts on AccountName
| where Timestamp between (AlertTime .. AlertTime + 24h)
| where DeviceName != CompromisedHost
| project Timestamp, AccountName, DeviceName, LogonType, CompromisedHost
```

D6 Discovery burst (KQL-style)

```
DeviceProcessEvents
| where FileName in~ ("net.exe","net1.exe","nltest.exe","whoami.exe","nslookup.exe","arp.exe")
| where AccountName !in (ITAdminWatchlist)
| summarize Tools = dcount(FileName), Events = count()
   by DeviceName, AccountName, bin(Timestamp, 10m)
| where Tools >= 4
```

D7 Unexpected remote access to a server (KQL-style)

```
DeviceLogonEvents
| where DeviceName in (FileServerWatchlist) and ActionType == "LogonSuccess"
| where LogonType in ("Network","RemoteInteractive")
| where AccountName !in (ServerAdminGroupMembers)
| project Timestamp, DeviceName, AccountName, RemoteDeviceName, RemoteIP, LogonType
```

D8 Data staging and compression on a file server (KQL-style)

```
DeviceFileEvents
| where DeviceName in (FileServerWatchlist) and ActionType == "FileCreated"
| summarize Files = count(), MB = sum(FileSize) / 1048576.0,
   Archives = countif(FileName endswith ".zip" or FileName endswith ".7z")
   by DeviceName, InitiatingProcessAccountName, FolderPath, bin(Timestamp, 15m)
| where Files > 500 or MB > 1024 or Archives > 0
```

D9 Beacon-like connections to a rare domain (Python / pandas)

```
import pandas as pd
df = pd.read_csv("sample-data/synthetic-events.csv", parse_dates=["timestamp"])
conn = df[df.event_type == "proxy_connection"].sort_values("timestamp")

def score(g):
    gaps = g.timestamp.diff().dt.total_seconds().dropna()
    mean = gaps.mean()
    return pd.Series({"n": len(g), "mean_s": mean,
                      "cv": gaps.std() / mean if mean else None})

res = conn.groupby(["src_host", "dest_domain"]).apply(score).reset_index()
rare = conn.groupby("dest_domain").src_host.nunique().rename("hosts_seen")
res = res.merge(rare, on="dest_domain")
alerts = res[(res.n >= 12) & (res.cv < 0.25) & (res.hosts_seen <= 2)]
print(alerts)
```

D10 Large outbound transfer vs host baseline (KQL-style)

```
let baseline = CommonSecurityLog
| where TimeGenerated between (ago(30d) .. ago(1d))
| summarize H = sum(SentBytes) by SourceIP, bin(TimeGenerated, 1h)
| summarize P99 = percentile(H, 99) by SourceIP;
CommonSecurityLog
| where TimeGenerated > ago(1d) and DeviceAction == "Allow"
| summarize BytesOut = sum(SentBytes)
    by SourceIP, DestinationHostName, bin(TimeGenerated, 1h)
| join kind=inner baseline on SourceIP
| where BytesOut > 3 * P99 and DestinationHostName !in (SanctionedServices)
```

B. Worked example for Part 10: cloud admin account creates a new mailbox forwarding rule

Question	Answer
What the evidence proves	An admin identity created or changed a forwarding rule (an audit record exists). It does not prove malicious intent, that mail was actually forwarded, or who was at the keyboard.
Most relevant tactic(s)	Collection (primary). Persistence if the rule keeps access after a password reset. Exfiltration if the rule forwards to an external address.
Possible techniques	T1114.003 Email Collection: Email Forwarding Rule; T1098.002 Additional Email Delegate Permissions if delegates were added; T1078.004 Cloud Accounts if the admin identity was misused.
Confidence and alternatives	Medium. Alternatives: legitimate admin action for leave cover, a migration, a shared mailbox, or a helpdesk ticket.
Telemetry to confirm	M365 unified audit log operations for inbox rules and mailbox forwarding settings, Entra sign-in logs (IP, MFA, device), change tickets and message trace to the destination.
Safe detection idea	Alert when a forwarding rule or address is set to an external domain, or set by an admin outside a change window, especially after a risky sign-in.
Defensive response	Verify with the account owner and admin out of band. If unverified: disable the rule, revoke sessions, reset admin credentials, review forwarded messages and search other mailboxes for similar rules.

C. Synthetic evidence excerpt

Illustrative rows in the format used by sample-data/synthetic-events.csv (fictional hosts, users and domains).

timestamp	src_host	user	event_type	detail
Mon 11:47	FIN-WS-07	fin.user1	process_create	parent=office_app child=script_engine (command omitted)
Mon 11:51	FIN-WS-07	fin.user1	task_created	trigger=at_logon action=user_writable_path
Mon 12:31	FS-01	fin.user1	logon	logon_type=remote_admin source=FIN-WS-07
Mon 12:42	FS-01	fin.user1	file_bulk_copy	files=2140 dest=temp_staging
Mon 13:05	FIN-WS-07	fin.user1	proxy_connection	dest_domain=rare-example.test interval=5min
Mon 14:18	FS-01	svc-copy	bytes_out	dest=unfamiliar-service.test bytes=large

D. Glossary (plain-language definitions)

Term	Meaning
ATT&CK	MITRE's public catalogue of how real attackers behave, organized as tactics and techniques.
Tactic / technique / sub-technique	Goal / method / specific version of the method.
SOC	Security Operations Center: the team that watches alerts and responds to incidents.
EDR	Endpoint detection and response: security software on laptops and servers that records activity and raises alerts.
Telemetry / logs	Records of what happened on systems, networks and accounts. Detection depends on them.
Phishing	A fake message designed to trick someone into clicking, opening a file or giving up their login.
Look-alike domain	A website or email name that resembles a real company's, such as one letter changed.
MFA	Multi-factor authentication: a second proof of identity in addition to the password.
Valid account	A real username and password used by the attacker, so activity can look normal.
Privileged account	An administrator-level account with wide powers. Attackers want it.

Term	Meaning
Persistence	The attacker's way of keeping access, for example a task that runs at every sign-in.
Scheduled task	A Windows feature that runs a program automatically at a set time or event.
Discovery	Looking around a network to learn what is there.
Lateral movement	Moving from one computer to another inside the network.
Staging	Collecting stolen files in one place before sending them out.
Beaconing / C2	Regular signals from an infected machine to the attacker's server (command and control).
Exfiltration	Sending data out of the organization without permission.
Impact	The final harm: files encrypted, deleted or made unusable.
False positive	An alert that fires on normal, harmless activity. Tuning reduces them.
Baseline	What normal looks like for a user, host or network, used to spot unusual activity.
Confidence level	How sure the analyst is: High, Medium or Low, with reasons.
Tamper protection	A security-tool feature that stops settings being switched off without approval.
Navigator	MITRE's free web tool for colouring techniques on the ATT&CK matrix.
KQL / Sigma	Query language (KQL) and a shared rule format (Sigma) used to write detections.